SRI LANKA INSTITUTE OF INFORMATION TECHNOLOGY

FACULTY OF COMPUTING.

WEB SECURITY- IE2062

IT22121592 – HERATH H.M.C.H.K

Y2S2

Contents

Subdomain Enumeration: 3
Vulnerability title. 3
Vulnerability description. 3
Affected components. 4
Impact assessment. 6
Steps to reproduce: 9
Proposed mitigation or fix: 11

Subdomain ‘manage.bigcommerce.com’

Subdomain Enumeration:

Vulnerability title.

Find hidden file.

Vulnerability description.

A hidden file vulnerability involves the exposure of important files stored in a web server to unauthorized individuals. This often occurs when developers overlook these files during the creation phase and can potentially disclose details, about the server setup or offer avenues, for attacks. Examples of files may include backup files, temporary files, and configuration settings.

When hidden files are accidentally revealed by web applications it can lead to a situation where attackers may have the chance to exploit vulnerabilities.

Uncover details. Configuration files and environment files such, as .env or backup files could potentially hold information, like credentials or API keys and database connection details.

Software versions can be determined by checking files such, as READMEs or debug logs which could potentially expose the version of the software in use and could be exploited by attackers through known vulnerabilities.

Look for access points such, as .git folders and undercover admin sections that could reveal security weaknesses not typically visible, to users.

Here are some files that are kept secret:

Files named ".env" that store variables used in applications.

Ensure you have copies of files such, as an index.php.bak, config. Old, and db.sql, for purposes.

Unseen temporary documents produced by editors, like index.php or Index.php.

Affected components.

When there’s a file vulnerability present it typically indicates that certain files intended to be private are inadvertently made accessible, on the website or server. These files could hold data such, as passwords, secret keys, or even the complete source code of the site. This scenario may occur when developers forget to remove files, configuration files, or temporary files used during editing.

Which components of the system show signs of impact?

The web Server:

Think of it like the entrance, to your website. If the server isn't configured correctly; it could unintentionally reveal information akin to sharing blueprints of your home (such, as configuration details or server pathways).

The Application code:

Imagine if you accidentally left your app's guidelines out, in the open for anyone to stumble upon. It could spell trouble if backup files or outdated code versions are left vulnerable since a malicious individual could analyze them to find a way to infiltrate the system.

The Database:

If unauthorized individuals gain access, to files containing details about your database (such as connection information and the entire database content) they could potentially misappropriate data by stealing it making alterations to it, or even erasing it entirely. This scenario is akin, to leaving a list of your crucial contacts and accounts in a visible location for anyone to see and exploit.

Authentication and access control:

Hidden files could potentially hold login details or access tokens. It's similar, to leaving your house keys out in the open for anyone to grab and use without permission If someone stumbles upon these files unexpectedly they could essentially impersonate you and infiltrate your system with undetected win system access.

Version control systems:

Programmers frequently utilize version control systems such, as Git to monitor code modifications effectively. If these systems are inadvertently left exposed to view it could be likened to granting access, to the record of your project. Exposing any errors or confidential information exchanged throughout the process.

Configuration files:

These files hold information regarding the configuration of your website or application (such, as passwords and database details). If these files are discovered by someone it's equivalent to giving them access, to your server keys.

Debug or Log Files detected:

When a mishap occurs in a systems operation it frequently generates records containing data regarding the issue at hand. If such documents are exposed to individuals it is akin, to laying down a path of hints that could be traced by an intruder seeking vulnerabilities, within your system.

Administrative Interfaces:

Exposed files could inadvertently reveal pathways to areas of a website – akin, to inadvertently leaving a back entrance to your home unlocked; if discovered by individuals, with ill intentions they could gain unauthorized access and wield full control.

What makes this such a significant issue?

If intruders come across these concealed documents and uncover the details, within them they could potentially breach your system gain access to information, or even take control of your website or server. It's akin, to stumbling upon a blueprint that reveals the locations of all your secured entrances and hidden chambers.

Impact assessment.

Analyzing the repercussions of a concealed file vulnerability assists, in gauging the extent of harm and outcomes should a potential attacker take advantage of this flaw within the system framework, Let's delve into the effects observed across dimensions of the system:

Confidentiality breach:

There is a possibility of data, like database login details or API access codes and personal user information (such as email addresses and passwords) being revealed.

Effect:

- Privacy breaches, due, to data leaks are a concern.
- Potential consequences include a decline, in customer confidence if there is a breach of data security.
- Consequences, in terms of the law, like GDPR or CCPA if user data gets leaked.

System compromise:

Warning on Revealing information such, as configuration files or source code could provide hackers with knowledge, about the system structure and operations.

Impact:

Criminals could utilize this data to carry out assaults like:

- Achieving privilege escalation involves obtaining administrative-level access.
- Executing code remotely involves the act of running code, on the server.

If the system loses control there could be activities such, as tampering with data or deleting information.

Data loss:

Exposure to files or database dumps poses a risk of access and potential alteration or deletion of data.

Effects:

- The loss or unauthorized alteration of business data could severely impact operations.
- Recovering data, from backups might be necessary. This could lead to downtime and disturbances.
- Losses, in finances, resulting from data breaches or ransom requests.

Reputation damage:

Exposure to data or a system breach can damage the organization's reputation.

The impact :

- Losing customer trust happens when sensitive information, like data or payment details gets leaked.
- Unfavorable publicity and criticism, from the media are particularly concerning when it involves security breaches.
- Potential risk of losing business partnerships or customers.

Financial loss:

Risk- Accessing hidden files may result in service disruptions or unauthorized access, to data leading to ransom demands or security breaches.

Effect:

- Financial losses can arise from disruptions or ransom payments and the expenses related to data recovery efforts.
- The ramifications of data breaches extend to damages such, as lost revenue, from disrupted operations and potential legal penalties or settlements.
- The expenses, for enhancing security have risen due, to the need to address vulnerabilities through audits and bolstering security measures.

Regulations and legal consequences:

Exposing customer data or confidential business information may result in breaches of data protection laws potentially causing implications, for the organization.

Impact:

- Penalties and fines may be imposed under regulations such, as GDPR (General Data Protection Regulation) HIPAA (Health Insurance Portability and Accountability Act), or CCPA (California Consumer Privacy Act), in cases where personal or sensitive information is compromised.
- Possible legal actions, from impacted clients or collaborators.
- Heightened attention, from authorities, necessitates audits and adherence protocols.

Further exploitation:

The potential danger lies in the possibility of individuals obtaining access, to system data or user logins and utilizing the system as a base, for initiating attacks.

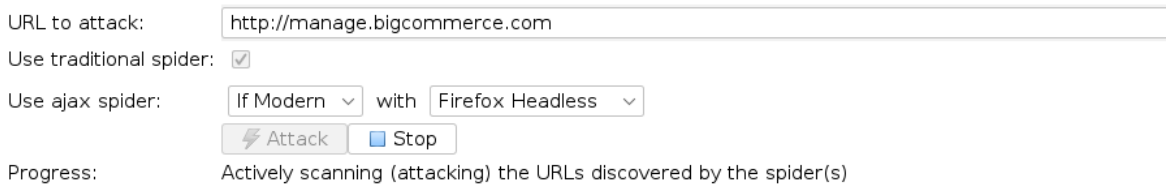
Effect:

- The attacker has the ability to move sideways from one compromised system to others in order to impact parts of the network.
- Utilize the hacked server to target systems (such, as companies or partners) or spread malicious software.
- Enlistment, in a botnet, could lead to the system being utilized in assaults, such, as DDoS attacks.

Overall impact severity:

- For companies that handle information like shopping sites banks, and medical facilities. Security is a top priority.
- For businesses in particular it can be challenging to handle as even a minor breach could harm their reputation and disrupt their operations significantly.
- In development environments, with security measures, in place exposing source code and configurations could potentially uncover security vulnerabilities.

Steps to reproduce:



Processed	Method	URI
	GET	https://manage.bigcommerce.com/assets/logo-8e3e5c57662b335ba913babd...
	GET	https://manage.bigcommerce.com/assets/404-icon-62bbfb3be512c1c3aa38c...
	GET	https://manage.bigcommerce.com/users/auth/bigcommerce
	GET	http://www.w3.org/2000/svg
	GET	http://www.w3.org/1999/xlink
	GET	http://www.bohemiancoding.com/sketch
	GET	https://fonts.googleapis.com/css?display=swap&family=Source+Sans+Pro:20...
	GET	http://fontawesome.io/
	GET	http://fontawesome.io/license
	GET	https://login.bigcommerce.com/oauth2/authorize?client_id=mw6orwssu8fs4p...

6 6 Main Proxy: localhost:8080

- Content Security Policy (CSP) Header Not Set
- Hidden File Found (4)
- Cookie No HttpOnly Flag

Hidden File Found

URL:	http://manage.bigcommerce.com/.hg
Risk:	Medium
Confidence:	Low
Parameter:	
Attack:	
Evidence:	HTTP/1.1 301 Moved Permanently
CWE ID:	538
WASC ID:	13
Source:	Active (40035 - Hidden File Finder)
Input Vector:	

Header: Text | Body: Text

```
HTTP/1.1 301 Moved Permanently
Content-Type: text/html
Location: https://manage.bigcommerce.com/.hg
X-Request-ID: 5ac912f7f9312b676e4cff35235612ea
Date: Fri, 18 Oct 2024 14:49:42 GMT
Via: 1.1 google
content-length: 166
```

```
<html>
<head><title>301 Moved Permanently</title></head>
<body>
<center><h1>301 Moved Permanently</h1></center>
<hr><center>openresty</center>
</body>
</html>
```

Description:
A sensitive file was identified as accessible or available. This may leak administrative, configuration, or credential information which can be leveraged by a malicious individual to further attack the system or conduct social engineering efforts.

Proposed mitigation or fix:

To safeguard your system against file vulnerabilities and prevent any harm they may bring about attack can take some straightforward measures to minimize the threat.

Limit access to documents:

- To enhance your website security measures set up your web server to restrict access, to file types or directories, like .env .git Backup files.
- It's similar, to securing the doors to rooms in your home where you keep private items safe and sound. Establishing guidelines in place ensures that only approved individuals or systems can view or access those documents.

- You can use the .htaccess file, for Apache or the nginx.conf file for NGINIX to control access, to folders and particular file formats.

Delete any files that are not needed:

- Make sure to tidy up your files and temporary files on your server by removing old code versions and development, and testing data.
- Leaving files scattered is akin, to leaving keys lying around in your house – if discovered by an attacker they could gain access, to areas of your system that you'd rather keep secure.
- Consider setting up the deletion of files through scripts or simply schedule reminders to tidy up your project folders manually.

Use proper file permissions:

- Ensure that you establish access controls, for files and folders, such as restricting access to configuration files solely to the system rather than allowing every visitor, to your website unrestricted entry.
- This procedure guarantees that only specific individuals or operations are permitted to access and modify files or run programs. Similar to how you would limit access, to areas of your home to yourself and trusted family members.
- You can adjust file permissions and ownership, on Linux using commands, like chmod and chown.

Disable Directory Listings:

- To prevent anyone from viewing a list of files when they access a folder without an index file, on your website server make sure to turn off directory listings.
- This method serves to deter individuals from sifting through your folders and accidentally coming across documents much like keeping someone from prying into all your storage spaces.

An example scenario in Apache involves the ability to deactivate this feature either by including "Options Indexes" in your .htaccess file or, in the configuration file.

Remember to check for any files that might be accessible on a basis:

- Regularly employ automated tools to scan your website or server for any files and potential security vulnerabilities.
- This process is akin, to having a security guard inspecting your homes doors and windows routinely for added protection against threats with scanning tools alerting you to any files that're accessible, without authorization.

Try using software such, as Nikto or Burpsuite to check for any security weaknesses in your system or consider utilizing tools, like OWASP ZAP for vulnerability scanning purposes.

Establishing a backup strategy is essential:

- Make sure to store backups in a location away, from the web and avoid placing them in directories accessible, via the internet.
- Having backups is important, in case of any mishaps, however it is crucial to store them to prevent exploitation by hackers. Imagine it as keeping your prized possessions in a safe, than leaving them scattered around the house.

Remember to keep your backups safe by storing them in places, like encrypted cloud storage instead of leaving them in the main directory of your website server.

Remember to make use of version control systems:

- Make sure not to reveal directories, like .git .Svn of version control systems when working with your live server environment.
- This method assists, by showing version control directories that expose every modification made to the codebase and even confidential updates to attackers – to keeping a record of each time you've secured your house door.

Make sure to set up your server in a way that prevents access, to version control files; alternatively, you could avoid uploading them to the server.

Monitor and Audit regularly:

- Regularly check file access and system logs to detect any attempts to access hidden files.
- This method is beneficial because ongoing surveillance enables you to detect issues to how inspecting your security cameras ensures that no unauthorized individuals have entered your home without detection.

Consider utilizing platforms such, as Splunk or ELA Stack for monitoring user activity and receiving notifications in case of any attempts to access data.

Teach your team effectively:

- Ensure that developers and IT personnel are aware of the dangers associated with leaving documents vulnerable and adhere to secure procedures when managing the website.
- It's important to develop security habits as they can help avoid leaks of information just, like ensuring that everyone, at home understands the importance of keeping doors locked and windows closed.

Make sure to organize security training sessions on a regular basis and use coding techniques that reduce security threats effectively.

Ensure Safe Development Methods:

- Remember to stick to secure coding practices to prevent the exposure of data, such, as credentials or API keys in files.
- This process helps to lower the risk of a document ending up in a location similar, to making sure important papers are not left scattered in random spots.

Try using environment variables of putting in sensitive data and make sure to keep them safe and well protected.